

Day 5 – Red Team Learning Today I explored Reconnaissance in MITRE ATT&CK.; Learned how attackers gather information before launching attacks. Techniques include: - Active Scanning - Vulnerability Scanning - Wordlist Scanning This phase is important because it helps attackers plan next steps. Understanding this helps in improving detection and defense.

TACTICS
Enterprise
Reconnaissance
Resource Development
Initial Access
Execution
Persistence
Privilege Escalation
Stealth
Defense Impairment
Credential Access
Discovery
Lateral Movement
Collection
Command and Control
Exfiltration
Impact
Mobile
ICS

Home > Tactics > Enterprise > Reconnaissance

Reconnaissance

The adversary is trying to gather information they can use to plan future operations.

Reconnaissance consists of techniques that involve adversaries actively or passively gathering information that can be used to support targeting. Such information may include details of the victim organization, infrastructure, or staff/personnel. This information can be leveraged by the adversary to aid in other phases of the adversary lifecycle, such as using gathered information to plan and execute Initial Access, to scope and prioritize post-compromise objectives, or to drive and lead further Reconnaissance efforts.

Techniques

Techniques: 12

ID	Name	Description
T1595	Active Scanning	Adversaries may execute active reconnaissance scans to gather information that can be used during targeting. Active scans are those where the adversary probes victim infrastructure via network traffic, as opposed to other forms of reconnaissance that do not involve direct interaction.
.001	Scanning IP Blocks	Adversaries may scan victim IP blocks to gather information that can be used during targeting. Public IP addresses may be allocated to organizations by block, or a range of sequential addresses.
.002	Vulnerability Scanning	Adversaries may scan victims for vulnerabilities that can be used during targeting. Vulnerability scans typically check if the configuration of a target host/application (ex: software and version) potentially aligns with the target of a specific exploit the adversary may seek to use.
.003	Wordlist Scanning	Adversaries may iteratively probe infrastructure using brute-forcing and crawling techniques. While this technique employs similar methods to Brute Force , its goal is the identification of content and infrastructure rather than the discovery of valid credentials. Wordlists used in these scans may contain generic, commonly used names and file extensions or terms specific to a particular software. Adversaries may also create custom, target-specific wordlists using data gathered from other Reconnaissance techniques (ex: Gather Victim Org Information , or Search Victim-Owned Websites).
T1592	Gather Victim Host Information	Adversaries may gather information about the victim's hosts that can be used during targeting. Information about hosts may include a variety of details, including administrative data (ex: name, assigned IP, functionality, etc.) as well as specifics regarding its configuration (ex: operating system, language, etc.).
.001	Hardware	Adversaries may gather information about the victim's host hardware that can be used during targeting. Information about hardware infrastructure may include a variety of details such as types and versions on specific hosts, as well as the presence of additional components that might be indicative of added defensive protections (ex: card/biometric readers, dedicated encryption hardware, etc.).
.002	Software	Adversaries may gather information about the victim's host software that can be used during targeting. Information about installed software may include a variety of details such as types and versions on specific hosts, as well as the presence of additional components that might be indicative of added defensive protections (ex: antivirus, SIEMs, etc.).
.003	Firmware	Adversaries may gather information about the victim's host firmware that can be used during targeting. Information about host firmware may include a variety of details such as type and versions on specific hosts, which may be used to infer more information about hosts in the environment (ex: configuration, purpose, age/patch level, etc.).
.004	Client Configurations	Adversaries may gather information about the victim's client configurations that can be used during targeting. Information about client configurations may include a variety of details and settings, including operating system/version, virtualization, architecture (ex: 32 or 64 bit), language, and/or time zone.
T1589	Gather Victim Identity Information	Adversaries may gather information about the victim's identity that can be used during targeting. Information about identities may include a variety of details, including personal data (ex: employee names, email addresses, security question responses, etc.) as well as sensitive details such as credentials or multi-factor authentication (MFA) configurations.
.001	Credentials	Adversaries may gather credentials that can be used during targeting. Account credentials gathered by adversaries may be those directly associated with the target victim organization or attempt to take advantage of the tendency for users to use the same passwords across personal and business accounts.
.002	Email Addresses	Adversaries may gather email addresses that can be used during targeting. Even if internal instances exist, organizations may have public-facing email infrastructure and addresses for employees.

Active Scanning

Sub-techniques (3)

Adversaries may execute active reconnaissance scans to gather information that can be used during targeting. Active scans are those where the adversary probes victim infrastructure via network traffic, as opposed to other forms of reconnaissance that do not involve direct interaction.

Adversaries may perform different forms of active scanning depending on what information they seek to gather. These scans can also be performed in various ways, including using native features of network protocols such as ICMP.^{[1][2]} Information from these scans may reveal opportunities for other forms of reconnaissance (ex: [Search Open Websites/Domains](#) or [Search Open Technical Databases](#)), establishing operational resources (ex: [Develop Capabilities](#) or [Obtain Capabilities](#)), and/or initial access (ex: [External Remote Services](#) or [Exploit Public-Facing Application](#)).

ID: T1595

Sub-techniques: T1595.001, T1595.002, T1595.003

① **Tactic:** Reconnaissance

① **Platforms:** PRE

Version: 1.0

Created: 02 October 2020

Last Modified: 24 October 2025

Version Permalink

Procedure Examples

ID	Name	Description
C0030	Triton Safety Instrumented System Attack	In the Triton Safety Instrumented System Attack, TEMP-Veles engaged in network reconnaissance against targets of interest. ^[3]

Mitigations

ID	Mitigation	Description
M1056	Pre-compromise	This technique cannot be easily mitigated with preventive controls since it is based on behaviors performed outside of the scope of enterprise defenses and controls. Efforts should focus on minimizing the amount and sensitivity of data available to external parties.

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0830	Detection of Active Scanning	AN1962	Monitor network data for uncommon data flows. Processes utilizing the network that do not normally have network communication or have never been seen before are suspicious. Monitor and analyze traffic patterns and packet inspection associated to protocol(s) that do not follow the expected protocol standards and traffic flows (e.g. extraneous packets that do not belong to established flows, gratuitous or anomalous traffic patterns, anomalous syntax, or structure). Consider correlation with process monitoring and command line to detect anomalous processes execution and command line arguments associated to traffic patterns (e.g. monitor anomalies in use of files that do not normally initiate connections for respective protocol(s)).

References

Active Scanning: Scanning IP Blocks

Other sub-techniques of Active Scanning (3)

Adversaries may scan victim IP blocks to gather information that can be used during targeting. Public IP addresses may be allocated to organizations by block, or a range of sequential addresses.

Adversaries may scan IP blocks in order to Gather *Victim Network Information*, such as which IP addresses are actively in use as well as more detailed information about hosts assigned these addresses. Scans may range from simple pings (ICMP requests and responses) to more nuanced scans that may reveal host software/versions via server banners or other network artifacts.^[1] Information from these scans may reveal opportunities for other forms of reconnaissance (ex: Search Open Websites/Domains or Search Open Technical Databases), establishing operational resources (ex: Develop Capabilities or Obtain Capabilities), and/or initial access (ex: External Remote Services).

ID: T1595.001

Sub-technique of: T1595

① Tactic: Reconnaissance

① Platforms: PRE

Contributors: Diego Sappa, Securonix

Version: 1.1

Created: 02 October 2020

Last Modified: 24 October 2025

Version Permalink

Procedure Examples

ID	Name	Description
C0062	Anthropic AI-orchestrated Campaign	During the <i>Anthropic AI-orchestrated Campaign</i> , the adversary used Claude Code to scan infrastructure across IP ranges associated with the target organization. ^[2]
G1003	Ember Bear	Ember Bear has targeted IP ranges for vulnerability scanning related to government and critical infrastructure organizations. ^[3]
G0139	TeamTNT	TeamTNT has scanned specific lists of target IP addresses. ^[4]

Mitigations

ID	Mitigation	Description
M1056	Pre-compromise	This technique cannot be easily mitigated with preventive controls since it is based on behaviors performed outside of the scope of enterprise defenses and controls. Efforts should focus on minimizing the amount and sensitivity of data available to external parties.

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0817	Detection of Scanning IP activity	AN1949	Monitoring the content of network traffic can help detect patterns associated with active scanning activities. This can include identifying repeated connection attempts, unusual scanning behavior, possible vulnerabilities, and the address ranges scanned.

Active Scanning: Vulnerability Scanning

Other sub-techniques of Active Scanning (3)

Adversaries may scan victims for vulnerabilities that can be used during targeting. Vulnerability scans typically check if the configuration of a target host/application (ex: software and version) potentially aligns with the target of a specific exploit the adversary may seek to use.

These scans may also include more broad attempts to Gather *Victim Host Information* that can be used to identify more commonly known, exploitable vulnerabilities. Vulnerability scans typically harvest running software and version numbers via server banners, listening ports, or other network artifacts.^[1] Information from these scans may reveal opportunities for other forms of reconnaissance (ex: Search Open Websites/Domains or Search Open Technical Databases), establishing operational resources (ex: Develop Capabilities or Obtain Capabilities), and/or initial access (ex: Exploit Public-Facing Application).

ID: T1595.002

Sub-technique of: T1595

① Tactic: Reconnaissance

① Platforms: PRE

Version: 1.0

Created: 02 October 2020

Last Modified: 24 October 2025

Version Permalink

Procedure Examples

ID	Name	Description
C0062	Anthropic AI-orchestrated Campaign	During the <i>Anthropic AI-orchestrated Campaign</i> , the adversary used Claude Code to scan target infrastructure to identify potential vulnerabilities and to enumerate services and endpoints. ^[2]
G0007	APT28	APT28 has performed large-scale scans in an attempt to find vulnerable servers. ^[3]
G0016	APT29	APT29 has conducted widespread scanning of target environments to identify vulnerabilities for exploit. ^[4]
G0096	APT41	APT41 used the Acunetix SQL injection vulnerability scanner in target reconnaissance operations, as well as the JexBoss tool to identify vulnerabilities in Java applications. ^[5]
G0143	Aquatic Panda	Aquatic Panda has used publicly accessible DNS logging services to identify servers vulnerable to Log4j (CVE 2021-44228). ^[6]
C0029	Cutting Edge	During <i>Cutting Edge</i> , threat actors used the publicly available Interactah tool to identify Ivanti Connect Secure VPNs vulnerable to CVE-2024-21893. ^[7]
G0035	Dragonfly	Dragonfly has scanned targeted systems for vulnerable Citrix and Microsoft Exchange services. ^[8]
G1006	Earth Lusca	Earth Lusca has scanned for vulnerabilities in the public-facing servers of their targets. ^[9]
G1003	Ember Bear	Ember Bear has used publicly available tools such as MASSCAN and Acunetix for vulnerability scanning of public-facing infrastructure. ^[10]
G0065	Leviathan	Leviathan has conducted reconnaissance against target networks of interest looking for vulnerable, end-of-life, or no longer maintainted devices against which to rapidly deploy exploits. ^[11]
G0090	Manic Mound	Manic Mound has conducted widespread scanning to identify public-facing systems vulnerable to CVE-2021-44728 in I nndi and ProwShell vulnerabilities: CVE-2021-26855, CVE-2021-26857

Active Scanning: Wordlist Scanning

Other sub-techniques of Active Scanning (3)

Adversaries may iteratively probe infrastructure using brute-forcing and crawling techniques. While this technique employs similar methods to [Brute Force](#), its goal is the identification of content and infrastructure rather than the discovery of valid credentials. Wordlists used in these scans may contain generic, commonly used names and file extensions or terms specific to a particular software. Adversaries may also create custom, target-specific wordlists using data gathered from other Reconnaissance techniques (ex: [Gather Victim Org Information](#), or [Search Victim-Owned Websites](#)).

For example, adversaries may use web content discovery tools such as [Dirb](#), [DirBuster](#), and [GoBuster](#) and generic or custom wordlists to enumerate a website's pages and directories.^[1] This can help them to discover old, vulnerable pages or hidden administrative portals that could become the target of further operations (ex: [Exploit Public-Facing Application](#) or [Brute Force](#)).

As cloud storage solutions typically use globally unique names, adversaries may also use target-specific wordlists and tools such as [s3recon](#) and [GCPBucketBrute](#) to enumerate public and private buckets on cloud infrastructure.^{[2][3]} Once storage objects are discovered, adversaries may leverage [Data from Cloud Storage](#) to access valuable information that can be exfiltrated or used to escalate privileges and move laterally.

ID: T1595.003

Sub-technique of: [T1595](#)

① **Tactic:** [Reconnaissance](#)

① **Platforms:** PRE

Contributors: Elvis Veliz, Citi, Jan Petrov, Citi, Richard Julian, Citi

Version: 1.0

Created: 04 March 2022

Last Modified: 24 October 2025

[Version](#) [Permalink](#)

Procedure Examples

ID	Name	Description
G0096	APT41	APT41 leverages various tools and frameworks to brute-force directories on web servers. ^[4]
G0123	Volatile Cedar	Volatile Cedar has used DirBuster and GoBuster to brute force web directories and DNS subdomains. ^[1]

Mitigations

ID	Mitigation	Description
M1042	Disable or Remove Feature or Program	Remove or disable access to any systems, resources, and infrastructure that are not explicitly required to be available externally.
M1056	Pre-compromise	This technique cannot be easily mitigated with preventive controls since it is based on behaviors performed outside of the scope of enterprise defenses and controls. Efforts should focus on minimizing the amount and sensitivity of data available to external parties.

Detection Strategy